



Findings compared. Claims kept separate.

Agent and MCP security / source-scanner research

Comparison v0.10 series | Recorded Invarune engine: 0.10.0 | 19 September 2026

PINNED PROJECTS	SOURCE OBSERVATIONS	FROZEN REVIEW SPANS
8	1,117	120

The useful result

Different scanners expose different review work. This comparison retains every observation and analysis gap, links exact source locations and identifies conservative overlap. It does not turn agreement, severity or model judgments into confirmed vulnerabilities.

Immediate priorities: inspect executable/deserialization and credential boundaries in context; close analysis gaps; validate agent reachability, tenant permissions and deployed safeguards before accepting or dismissing a concern.

The complete online ledger contains 1,117 source observations. This PDF shows representative cases and explicit denominators instead of repeating the entire ledger.

[Open the complete finding-by-finding ledger](#)

[Machine-readable evidence, receipts and reproducible methods](#)

Contents

Click an entry or use PDF bookmarks. This is a research report, not an editable scan-review capsule.

Findings compared. Claims kept separate.	1
01 / What ran and what the counts mean	3
02 / Analysis completeness and source scope	4
03 / Conservative finding-by-finding overlap	5
04 / Frozen selection and unresolved accuracy	6
05 / Representative observations and agent relevance	8
06 / Shared fixtures and the Inspector correction	10
07 / Initial versus current engine evidence	11
08 / Other security layers and current tool research	12
09 / Sources, artifacts and reproducibility	13

01 / What ran and what the counts mean

32 normalized project/tool run records cover 8 pinned public source exports (4,120 exported files). The same exported bytes were offered to each source scanner; supported languages, parser outcomes and active rules differ.

One observation is one scanner-reported source record. It is not necessarily one distinct vulnerability. Repeated Invarune executions are repeatability checks and do not multiply the observation denominator.



Observation volume only; different rule scopes. No quality ranking.

Source tool	Recorded version	Observations	Relevant scope
Invarune	0.10.0	149	Agent/MCP and shared source/configuration patterns
Semgrep CE	1.177.0	27	CE engine; frozen 225-rule audit pack
Bandit	1.9.4	938	Packaged Python plugins; includes imports/assertions
Gitleaks	8.30.1	3	Directory secret patterns; no Git-history run

Do not compare a library import, a policy warning, a dangerous API call, an active attack success and a confirmed exploitable vulnerability as interchangeable units. A lower count can reflect narrower scope, different predicates or incomplete analysis.

[Tool configurations, versions and ruleset hashes](#)

02 / Analysis completeness and source scope

Tool	Run records	Runs with errors/gaps	Unsupported inputs	Reported errors / gaps
Invarune	8	4/8	0	14 errors; 15 gaps
Semgrep CE	8	3/8	0	7 errors; 0 gaps
Bandit	8	1/8	2	5 errors; 0 gaps
Gitleaks	8	0/8	0	0 errors; 0 gaps

Error and gap counts describe each tool own receipt schema; they are not equivalent coverage units and must not be summed into an accuracy denominator. Unsupported Bandit exports are not clean Python scans. A successful process can still report parser warnings or partial analysis.

Project-level recorded statuses

Project	Invarune	Semgrep	Bandit	Gitleaks
autogen	13	6	183	0
crewai	28; partial	8; partial	232; partial	0
fastmcp	0	2	95	1
github-mcp	15	1; partial	N/A	0
langgraph	23; partial	8	84	1
mcp-reference	61	0	0	0
openhands	9; partial	0; partial	N/A	1
pydantic-ai	0; partial	2	344	0

Cells show observation counts; partial means errors or gaps are recorded. N/A means unsupported input. Generated templates, unsupported syntax and parser limitations can hide relevant implementation paths; inspect the raw statuses before claiming another scanner missed an issue.

[Complete run statuses and error records](#)

[Pinned source manifests, project commits and licenses](#)

03 / Conservative finding-by-finding overlap

Same project, pinned path, explicitly mapped compatible family and inclusive intersecting line spans. No line-distance tolerance. Many-to-many edges are ambiguous; location-only edges retain unrelated/unmapped observations.

A one-to-one pair requires each observation to have exactly one compatible counterpart. Many-to-many edges remain ambiguous. Location-only relations overlap a span but differ in family or mapping; none of these relations supplies a correctness label.

Pair (left / right)	1:1 pairs	Ambiguous edges	Location-only	Left unmatched / all	Right unmatched / all
Invarune / Semgrep CE	7	0	0	142/149	20/27
Invarune / Bandit	12	5	0	132/149	925/938
Invarune / Gitleaks	1	0	0	148/149	2/3
Semgrep CE / Bandit	15	0	3	12/27	923/938
Semgrep CE / Gitleaks	0	0	0	27/27	3/3
Bandit / Gitleaks	0	0	0	938/938	3/3

The unmatched denominator is the relevant tool observation count in that pair. Ambiguous edges can share endpoints, so edge counts must not be interpreted as unique shared issues. Pairwise rows are not additive across tools.

Tool-only is not a missed vulnerability. First establish compatible rule predicates, successful analysis of the affected language/file, a valid security use and the relevant trust boundary. Different source spans remain unmatched rather than being guessed into alignment.

[Every match, ambiguous edge and unmatched observation ID](#)

[Explicit compatible families and review predicates](#)

04 / Frozen selection and unresolved accuracy

Before reading any model outcomes, the recorded selection froze 120 exact spans containing 153 observations from a 1117-observation ledger. It covers 101/101 observed tool/project/family strata.

All Semgrep and Gitleaks observations mandatory; deterministic greedy coverage of every observed tool/project/family stratum; no-family-match example per tool; hash-ranked fill to 120 exact source spans.

Purposive stratified diagnostic selection, not a random prevalence sample; no population precision estimate without a different sampling design. TP/FP labels are intentionally absent.

Selection coverage is a workload measure, not a confidence interval or accuracy estimate. Unreviewed observations remain unknown; they are not false positives. Labels for the frozen historical observations must not silently be reassigned to new detections.

Tool	Selected historical observations	Historical source observations	Selected share
Invarune	28	149	18.8% (28/149)
Semgrep CE	27	27	100.0% (27/27)
Bandit	95	938	10.1% (95/938)
Gitleaks	3	3	100.0% (3/3)

Selected IDs still present in the current ledger: 153/153. A changed detector version can create or remove observations; preserved selection provenance remains tied to its original input digest.

Frozen algorithm, seed, selection ID and all selected spans

Optional Claude adjudication: actual attempt and coverage

1 live request attempts are recorded. Authentication blocked remaining work: True. Accepted model answers: 0/153 selected observations. Prepared evidence and an attempted request are not model answers.

The selection remains bound to its original historical ledger. Actual preparation separately binds observations.json (Invarune 0.10.0), with every selected observation identity checked across both inputs. Model artifact SHA-256: 6526d93cf9db3eacebd87eb72f5f95ef8f078a866f1e80c983077697840a0671

Tool	Accepted / selected	Likely TP / likely FP	Runtime / insufficient	No accepted answer
Invarune	0/28	0 / 0	0 / 0	28
Semgrep CE	0/27	0 / 0	0 / 0	27
Bandit	0/95	0 / 0	0 / 0	95
Gitleaks	0/3	0 / 0	0 / 0	3

Model likely-TP point estimate: unavailable. There are zero accepted adjudicable answers, so no 0% TP claim is calculated. All selected observations remain unknown for that estimate.

Selected-sample accounting bounds, treating every unresolved item as either negative or positive: 0.0% to 100.0% across all 153 selected observations. These are missing-label bounds, not statistical confidence intervals or production accuracy.

No independent human ground truth or confirmed exploitability is supplied by this model track. Unattempted or invalid answers are not false positives, and tool agreement is not used as a label.

[Actual model attempt, status and exhaustive selected-row audit](#)

Separate Codex-assisted source-predicate audit

Recorded status: completed. Source-review rows present: 50/50 selected observations. This is agent-assisted source review, not independent human ground truth, Claude adjudication or runtime testing.

Not fully blind: selection and lead reviewer saw tool metadata. A delegated reviewer receives family predicates without tool names/severities; this is not independent ground truth.

Tool	Reviewed / selected	Source predicate supported	Conditional mismatch	Insufficient evidence
Invarune	28/28	23	5	0
Semgrep CE	9/9	9	0	0
Bandit	10/10	10	0	0
Gitleaks	3/3	0	3	0

A supported source predicate means the cited syntax/configuration supports that narrow rule claim. It does not establish an exploitable vulnerability or deployment exposure. Conditional mismatches, such as an example/error string or non-security use, require interpretation of the actual rule predicate. No percentage from these labels is presented as production precision.

For the three selected Gitleaks records, the audit distinguishes the benchmark claim of a private or usable secret from the native rule's broader lexical pattern. A public credential identifier or documented example can match that native pattern while failing the narrower benchmark predicate; these are not established Gitleaks detection errors.

[Complete source audit with pinned line evidence and rationale](#)

[Readable source-audit scope, selected findings and limits](#)

05 / Representative observations and agent relevance

These illustrations are selected deterministically from current match relations and named families, without consulting any model outcome. They are examples of review work, not a verdict on the upstream projects. Source links point to the pinned commit.

1. Invarune / AI005

One-to-one family/location agreement | autogen | [python/packages/autogen-ext/src/autogen_ext/experimental/task_centric_memory/_memory_bank.py:82-82](#)

Scanner claim: Executable deserialization requires trusted inputs

Review predicate: A pickle-family API is invoked; identify whether it serializes or deserializes and whether deserialized bytes cross a trust boundary.

Agent/MCP applicability: Executable deserialization can cross an agent artifact/cache trust boundary. Serialization and imports are different operations; identify the exact call and whether input bytes can come from an untrusted producer.

Observation ID: obs-2f81af7022a056475a108a00 | Recorded engine 0.10.0 | Status: unverified observation

[Inspect pinned source location](#)

Counterpart: Semgrep CE / [python.lang.security.deserialization.pickle.avoid-pickle](#) / obs-8df234b76575f0ce3cd9e6b9. Compatible location/family does not establish identical semantics or ground truth.

[Inspect counterpart pinned span](#)

2. Invarune / AI010

Ambiguous family/location relation | crewai | [lib/cli/src/crewai_cli/deploy/validate.py:102-102](#)

Scanner claim: Credential-like literal in source or configuration

Review predicate: A literal resembles a credential assignment/argument/token; verify its actual role, excluding placeholders, error labels, public identifiers and examples.

Agent/MCP applicability: If this is a live credential used by a model gateway or downstream tool, copying it can bypass the normal agent session. Classify it without revealing the value; test/example strings are not automatically secrets.

Observation ID: obs-2d5523f29b2248f832b29424 | Recorded engine 0.10.0 | Status: unverified observation

[Inspect pinned source location](#)

Counterpart: Bandit / B105 / [obs-fed18e8e5cba56beebbf5100](#). Compatible location/family does not establish identical semantics or ground truth.

[Inspect counterpart pinned span](#)

3. Invarune / AI025

No family/location match with Semgrep CE | autogen | [python/packages/autogen-studio/requirements.txt:1-1](#)

Scanner claim: Direct dependency is not exactly pinned

Review predicate: A direct dependency declares a non-exact version; frozen lockfiles and verified install behavior may mitigate the policy concern.

Agent/MCP applicability: A movable dependency can change the agent or MCP runtime and its security behavior. Check the effective lockfile and installation command before treating a version range as uncontrolled installation.

Observation ID: obs-c86c09e8c3c9e66ab1c4e378 | Recorded engine 0.10.0 | Status: unverified observation

[Inspect pinned source location](#)

4. Bandit / B101

No family/location match with Invarune | autogen |
python/packages/autogen-agentchat/src/autogen_agentchat/agents/_assistant_agent.py:971-971

Scanner claim: Assert statement

Review predicate: An assert statement exists; whether it is an authorization/input-validation boundary lost under Python optimization requires context.

Agent/MCP applicability: An assertion matters to agent security when it enforces authorization or input constraints that disappear under optimization. Many assertions express internal invariants; the source predicate alone does not establish an exploitable gap.

Observation ID: obs-b5cbc11dfb8ed2ca1b1531fc | Recorded engine 1.9.4 | Status: unverified observation

[Inspect pinned source location](#)

5. Semgrep CE / python.lang.security.deserialization.pickle.avoid-pickle

No family/location match with Invarune | autogen |
python/packages/autogen-ext/src/autogen_ext/experimental/task_centric_memory/_memory_bank.py:114-114

Scanner claim: Pickle family api

Review predicate: A pickle-family API is invoked; identify whether it serializes or deserializes and whether deserialized bytes cross a trust boundary.

Agent/MCP applicability: Executable deserialization can cross an agent artifact/cache trust boundary. Serialization and imports are different operations; identify the exact call and whether input bytes can come from an untrusted producer.

Observation ID: obs-6fbb3b0a1975249a424dfea9 | Recorded engine 1.177.0 | Status: unverified observation

[Inspect pinned source location](#)

6. Gitleaks / generic-api-key

No family/location match with Invarune | fastmcp | fastmcp_slim/fastmcp/server/auth/providers/google.py:245-245

Scanner claim: Credential literal

Review predicate: A literal resembles a credential assignment/argument/token; verify its actual role, excluding placeholders, error labels, public identifiers and examples.

Agent/MCP applicability: If this is a live credential used by a model gateway or downstream tool, copying it can bypass the normal agent session. Classify it without revealing the value; test/example strings are not automatically secrets.

Observation ID: obs-be342960cf98e3b44b7acdcf | Recorded engine 8.30.1 | Status: unverified observation

[Inspect pinned source location](#)

06 / Shared fixtures and the Inspector correction

A separate development-visible fixture receipt tests five API patterns with a positive and negative example each: dynamic eval, shell subprocesses, unsafe YAML, pickle loading and disabled TLS verification. Only the mapped API-pattern assertion is scored; unrelated observations do not become errors for that assertion.

Recorded fixture Invarune version: 0.10.0. These results remain attached to that execution, even when this PDF summarizes a later source-scan engine.

Tool	Positive hits / positives	Correct negative labels / negatives	False positive / false negative
Invarune	5/5	5/5	0 / 0
Semgrep CE	5/5	5/5	0 / 0
Bandit	5/5	5/5	0 / 0

Five hits out of five selected positive labels supports a 100% hit rate only for those five cases. This is not production recall, precision, exploitability or full agent/MCP coverage. Gitleaks and metadata tools are outside this fixture scope and receive no artificial true negatives.

[Exact fixture cases, labels, tool mappings and execution receipts](#)

AI041: an authentication-bypass configuration trap

Current official Inspector documentation says any nonempty DANGEROUSLY_OMIT_AUTH value disables authentication, including the strings false and 0. Remediation must unset the variable; setting it to false is not the safe counterexample. The detector and development-corpus labels were corrected, with the previous corpus preserved.

This is a documented configuration-semantics correction, not proof of exploitation in the public projects. AI041 is outside the five-pattern fixture set above. Initial v0.9 observations remain historical; any v0.10 detection changes belong to a new recorded execution.

[Official Inspector environment-variable semantics](#)

[Correction regressions and unsafe-value matrix](#)

07 / Initial versus current engine evidence

Evidence snapshot	Invarune version	Invarune observations	Total source observations
Preserved initial source run	0.9.0	149	1117
Current normalized source ledger	0.10.0	149	1117

Invarune observation identity comparison: 149 retained, 0 added, 0 absent from the current ledger. These are detection-set changes, not fixed vulnerabilities or newly proven defects.

Observation IDs deliberately exclude engine version, while each row retains its actual tool version and raw-report digest. A missing observation may reflect a changed detector, rule mapping or scope. Consult the source and execution receipt before interpreting a change.

Archived Invarune 0.9.0 receipts: 16 recorded executions across 8 projects; 8/8 projects report byte-identical repeated outputs. This measures repeatability under those recorded inputs, not correctness.

[Preserved v0.9 observations](#)

[Current source observations](#)

08 / Other security layers and current tool research

Cisco MCP Scanner 4.8.4 recorded 0 findings over 14 extracted literal tool descriptions using YARA only. This is partial offline metadata, not a live tools/list inventory, input-schema validation or runtime assessment.

Researched but unexecuted in this experiment: Snyk Agent Scan 0.6.3, SPLX Agentic Radar 0.14.1 and Promptfoo MCP red teaming. Their inventory, cloud, workflow or runtime capabilities are different units; no score or clean-result credit is assigned.

Source evidence still needs the deployment layers below

Boundary	What source observations can suggest	Additional evidence required
Tool execution	Dynamic code, shell, SQL or template sinks	Caller/resource policy, argument tests and actual worker isolation
MCP identity	Authentication flags, token forwarding and HTTP settings	Issuer/audience validation, tenant separation and direct-route denial tests
Agent decisions	Privileged prompt input and broad tool grants	Indirect-injection evaluation and approvals bound to actual effects
Data and artifacts	Secret patterns, unsafe loaders and mutable dependencies	Credential validity/rotation, provenance, access policy and separate CVE checks

These are proposed verification layers. A model expert can help prioritize or interpret supplied evidence, but a deterministic protocol validator only constrains the response format and evidence links. It cannot convert model confidence into ground truth.

[Current primary-source tool research and scope distinctions](#)

[Invarune source-linked remediation catalog](#)

[Primary MCP security guidance](#)

09 / Sources, artifacts and reproducibility

All metrics in this PDF are derived from the local checked-in ledgers and validated accounting at build time. Source URLs are clickable references, not instructions to fetch or execute anything. Raw tool messages and source snippets are not reproduced as the complete ledger; the normalized source records retain native rule identifiers for inspection.

[Complete online finding ledger \(1,117 rows\)](#)

[README.md](#)

[RESEARCH.md](#)

[observations.json](#)

[overlaps.json](#)

[run-status.json](#)

[adjudication-selection.json](#)

[observations-selection-v1.json](#)

[tool-lock.json](#)

[external-results/shared-pattern-fixtures.json](#)

[external-results/cisco-metadata.json](#)

Input artifact SHA-256 values

Input artifact	SHA-256
adjudication-live/preparation.json	f7d00b5ae7a0713034b7bc644e8b8cad0010493c2b15a79580bb1be11b1a0812
adjudication-prepared/preparation.json	f7d00b5ae7a0713034b7bc644e8b8cad0010493c2b15a79580bb1be11b1a0812
adjudication-selection.json	19c3dc57b1f582e0c0f239c0f6448b8717bede5775e09f59d8f8a05b3e06f8c3
external-results/cisco-metadata.json	7608e3d0824da0fc719469f315846ac9e2a42837554f9124d6d4b8eda36217c2
external-results/shared-pattern-fixtures.json	933067827f1414927235eb0776f368baba823fe701c93d35d00270aa71f4e4ed
observations-selection-v1.json	a6b6ff3d896859c1281017f2c4e05de0e022a348880bc30cd8f68b477aeceb
observations-v090.json	b663ffcb2859f86c50eb0b29594b36f4765cc9cbb199868309e922d95cae3164
observations.json	f26958d6565e2a304737e5fab0067b10e9714d5246b97b7b273489563af06dcc
overlaps.json	79743bdbe134bd3073190b30f5d72069d4b5208490c71347514c736ef6b0e75e
run-status-v090.json	0716adca18f62cbcdcc65518b9cd903350bd6c0f8bbc20882efbcc0297b5373a
run-status.json	dd91c078e3fdc2ddfe1b886d3461fce5dcf93d786bc0d92054957c3d2a18f0a0
source-audit.json	6c6f5bbb77f90b3511e03d3ba6fd99359083e4f17a5552ff9c993f2f39483a4a
tool-lock.json	3281101632b908168b250adb5073f6af8947979159a8d350c195337ef0ca0c00

Rebuild and validate

```
python3 scripts/build_finding_comparison_report.py --validate-only
```

```
python3 scripts/build_finding_comparison_report.py --output output/pdf/invarune-finding-comparison-v010.pdf
```

Rendering requires the authoring-only ReportLab dependency. The builder does not scan targets or call a model. Review the final PDF visually before distributing it; text extraction does not establish layout fidelity.